

Documentation – Reverse Proxy Nginx avec Authelia et Wazuh

1. Objectif

Mettre en place un **reverse proxy sécurisé** avec Nginx permettant :

- L'accès au dashboard Wazuh via HTTPS
 - La protection par authentification forte avec Authelia (SSO / 2FA)
 - Une séparation réseau propre (Authelia sur un serveur Docker distinct)
-

2. Architecture

◇ Composants

Service	IP	Port	Description
Nginx (Reverse Proxy)	10.0.20.2	443	Point d'entrée HTTPS
Wazuh Dashboard	10.0.40.3	443	Interface web
Authelia	10.0.40.5	9091	Authentification

◇ Flux de fonctionnement

1. L'utilisateur accède à :

`https://wazuh.cyna.labo`

2. Nginx intercepte la requête
3. Nginx appelle Authelia via :

`/api/verify`

4. Deux cas :
 -  Authentifié → accès à Wazuh

-  Non authentifié → redirection vers :

<https://authelia.cyna.labo>

3. Configuration Nginx

 **Fichier : </etc/nginx/sites-available/authelia>**

```
server {
    listen 80;
    server_name auth.cyna.labo;

    location / {
        proxy_pass http://127.0.0.1:9091;
        proxy_set_header Host $host;
        proxy_set_header X-Real-IP $remote_addr;
    }
}
```

 **Fichier : </etc/nginx/sites-available/wazuh>**

```
server {
    listen 443 ssl;
    server_name wazuh.cyna.labo;

    # =====
    # CERTIFICAT SSL
    # =====
    ssl_certificate /etc/ssl/wazuh/wazuh.crt;
    ssl_certificate_key /etc/ssl/wazuh/wazuh.key;

    # =====
    # WAZUH DASHBOARD
    # =====
    location / {

        # Appel à Authelia
        auth_request /authelia;

        # Redirection si non authentifié
        error_page 401 =302 https://authelia.cyna.labo/?rd=$scheme://$host$request_uri;

        # Backend Wazuh
```

```

proxy_pass http://10.0.40.3;

# Headers obligatoires
proxy_set_header Host $host;
proxy_set_header X-Real-IP $remote_addr;
proxy_set_header X-Forwarded-For $proxy_add_x_forwarded_for;
proxy_set_header X-Forwarded-Proto $scheme;
}

# =====
# AUTHELIA (AUTH REQUEST)
# =====
location = /authelia {
    internal;

    proxy_pass https://10.0.40.5:9091/api/verify;

    # Désactivation vérification SSL (certificat self-signed)
    proxy_ssl_verify off;

    # Headers nécessaires à Authelia
    proxy_set_header Host authelia.cyna.labo;
    proxy_set_header X-Original-URL $scheme://$host$request_uri;
    proxy_set_header X-Forwarded-Method $request_method;
    proxy_set_header X-Forwarded-Proto $scheme;
    proxy_set_header X-Forwarded-For $remote_addr;
}
}

```

4. 🔍 Points techniques importants

✓ 1. Auth_request

auth_request /authelia;

- Permet de déléguer l'authentification à Authelia
 - Ne transmet **pas** la requête complète, seulement une validation
-

✓ 2. Redirection vers Authelia

error_page 401 =302 https://authelia.cyna.labo/?rd=...

- **rd** = URL de retour après login
- Essentiel pour une UX propre

✓ 3. Proxy vers Wazuh

proxy_pass http://10.0.40.3;

- Wazuh fonctionne en HTTPS en interne mais peut être proxifié en HTTP
- Sinon possible d'utiliser HTTPS avec :

```
proxy_pass https://10.0.40.3;  
proxy_ssl_verify off;
```

✓ 4. Problème rencontré (et corrigé)

✗ Avant :

- Authelia accessible uniquement en IP Docker (172.x.x.x)

✓ Solution :

- Port exposé :

0.0.0.0:9091 -> 9091

- Accès OK via :

https://10.0.40.5:9091

5. 🧪 Tests de validation

◇ Test Authelia

curl -vk https://10.0.40.5:9091/api/health

✓ Résultat attendu :

```
{"status":"OK"}
```

◇ Test Wazuh direct

curl -vk https://10.0.40.3

✓ Résultat attendu :

302 Found → /app/login

◇ Test via Nginx

curl -vk https://wazuh.cyna.labo

✓ Résultat attendu :

- Redirection vers Authelia si non connecté
 - Accès Wazuh si authentifié
-

6. Sécurité (actuel vs amélioration)

● Actuellement

- Certificats **self-signed**
- `proxy_ssl_verify off`

👉 OK pour lab, pas production

● Améliorations futures

- Mise en place d'une PKI interne
- Activation de :

`proxy_ssl_verify on;`

- Mutual TLS possible entre services
-

7. Bonnes pratiques retenues

- ✓ Séparation réseau (VLAN)
 - ✓ Authentification centralisée (Authelia)
 - ✓ Reverse proxy unique (Nginx)
 - ✓ Services isolés (Docker)
-

8. Conclusion

Ton architecture est maintenant :

- ✓ Fonctionnelle
- ✓ Propre
- ✓ Évolutive
- ✓ Sécurisable facilement (PKI ensuite)